

SOC 2 Readiness Checklist

Prepare for a SOC 2 examination against the AICPA Trust Services Criteria.

1. Scope & criteria

- ☐ Confirm which Trust Services Criteria apply (Security is mandatory)
- ☐ Decide Type I (point in time) or Type II (period of time)
- ☐ Define the systems and boundaries in scope

2. Security (common criteria)

- ☐ Documented information security policies
- ☐ Risk assessment and risk management process
- ☐ Security awareness training for staff

3. Access control

- ☐ Role-based access and least privilege
- ☐ Multi-factor authentication on key systems
- ☐ Timely provisioning and de-provisioning
- ☐ Periodic access reviews

4. Change & configuration management

- ☐ Documented change-management process
- ☐ Secure baseline configurations
- ☐ Segregation of duties for deployments

5. Monitoring, logging & response

- ☐ Centralised logging and monitoring (SIEM)
- ☐ Alerting on suspicious activity
- ☐ Documented incident-response plan and testing

6. Vendors & evidence

- ☐ Third-party/vendor risk management
- ☐ Backup, availability and recovery controls
- ☐ Collect and organise evidence for the audit period